

Guide de génération de démos — Gëstu Comply

Destinataire : un outil / agent IA chargé de produire des démonstrations réalistes de Gëstu (données d'exemple, scénarios de mission, parcours de démonstration). Ce document est un **référentiel factuel** : produit, vocabulaire, modèle de données, valeurs autorisées (enums), référentiels, workflows, modèle de score, et **règles de réalisme**. Toutes les valeurs sont extraites du code source ; respecte-les à la lettre (les enums sont contraints par des `CHECK` en base — une valeur hors liste sera rejetée).

Contexte produit clé, à toujours garder en tête : plateforme **francophone**, orientée **Sénégal / Afrique de l'Ouest**, monnaie **FCFA**, cadre phare **PSSI-ES** (État du Sénégal). Un nom d'entreprise, un secteur ou un montant « à l'américaine » casse immédiatement le réalisme.

1. Qu'est-ce que Gëstu ?

Gëstu Comply est le premier module de **Gëstu ETP** (*Enterprise Trust Platform*), une suite autour de la **confiance numérique**. Comply est une **plateforme multi-référentiels de contrôle de conformité et d'audit SI** (global ou sectoriel). Les **référentiels sont maintenus par Gëstu**, jamais par les clients.

- Nom de marque : **Gëstu** (le **tréma doré sur le « ë » est obligatoire**). Couleurs : vert forêt `#1B4332`, accent Comply `#40916C`, or `#D4A843` (signature Regul).
- Langue : **français** partout (UI, libellés d'enums).

Modèle B2B2B — trois segments

- Cabinets de conseil** (priorité V1) : un cabinet réalise des **missions** pour ses **clients** ; l'accès client est limité à la durée de la mission.
- Entreprises / Groupes / Holdings** : supervisent leurs filiales.
- Fonds d'investissement** : due diligence + conformité de portefeuille.

Modules / éditions

Un module = une **capacité** (`org_capability`). Valeurs canoniques : `comply | risk | policy | privacy | awareness | incidents | measures | supervision`. Le catalogue produits ajoute `regul` et `quality`.

- Comply** : audit & conformité (le cœur, décrit ici).
- Risk** : registre de risques (scénarios + liens contrôles).
- Policy** : gouvernance documentaire.
- Regul** : édition régulateur (voir ci-dessous).

La notion d'« édition » est résolue **au runtime** par deux axes : **capacités** (`organization_capabilities`) + **vocabulaire par org** (`organization_vocab`), via les RPC `my_capabilities()` / `my_vocab()`.

Comply vs Regul (bascule de persona)

Le « ressenti régulateur » = capacités `supervision + measures + incidents`. Le front dérive le persona de la capacité `supervision` : présente → **Regul**, absente → **Comply**. Le vocabulaire change (voir §3). Le

régulateur de référence est la **DCSSI** (Sénégal), qui audite via le moteur **contrôle** sur le référentiel **PSSI-ES**.

2. Modèle de données (entités principales)

Table	Signification métier
<code>organizations</code>	Cabinets, groupes, fonds, clients. <code>types: string[]</code> (une org peut être ["cabinet","client"]). <code>parent_org_id</code> pour groupes/filiales.
<code>cabinet_clients</code>	Fiche client du cabinet (lien cabinet ↔ org client). Porte <code>is_demo</code> , <code>demo_owner_id</code> .
<code>tenant_configs</code>	Config marque blanche par org.
<code>users</code>	Utilisateurs. <code>role</code> ∈ auditor / client (+ <code>is_platform_owner</code> orthogonal).
<code>platform_roles</code> / <code>user_platform_roles</code>	Rôles configurables, <code>permissions: jsonb</code> .
<code>frameworks</code> → <code>domains</code> → <code>controls</code>	Référentiel → domaines → contrôles (maintenus par Gëstu).
<code>questionnaire_templates</code> → <code>questions</code>	Questionnaires de cadrage.
<code>missions</code>	Lie cabinet, client, référentiel, chef de mission, associé. Fige <code>workflow_version</code> + <code>kind</code> .
<code>mission_members</code>	Équipe + rôle sur la mission.
<code>mission_control_assignments</code>	Quel auditeur traite quel contrôle.
<code>control_planning</code>	Par contrôle : <code>risk_level</code> , <code>estimated_hours</code> .
<code>control_assessments</code>	Travail sur un contrôle (<code>status</code> , <code>conformity_level</code> , notes de preuve).
<code>assessment_findings</code>	Constats (classification, priorité, risque, recommandation).
<code>assessment_validations</code>	Historique de la cascade de validation (<code>stage</code> , <code>decision</code>).
<code>assessment_observations</code>	Observations non bloquantes du client sur un constat.
<code>corrective_action_requests</code>	Plan d'action correctif (CAR, code CAR-001 ..., statut, échéance).
<code>client_contacts</code> / <code>interview_schedules</code>	Contacts client + entretiens.
<code>control_comments</code>	Discussion sur un contrôle.
<code>reports</code>	Rapports générés (PDF/PowerPoint), versionnés.
<code>risk_scenarios</code> / <code>risk_control_links</code>	Registre Gëstu Risk (scénario + liens contrôles).
<code>supervision_cycles</code>	Cycles de supervision continue (Regul).
<code>regulatory_measures</code>	Mesures graduées du régulateur (Regul).

Table	Signification métier
<code>regulatory_catalog</code>	Catalogue d'obligations légales/réglementaires (≈22 entrées) — distinct de <code>frameworks</code> .
<code>organization_relationships</code>	Arêtes d'engagement (nature <code>audit_engagement</code>).

Hiérarchie de travail : `mission` → (contrôles du `framework`) → `control_assessments` → `assessment_findings` → `corrective_action_requests`. Le score de confiance agrège les évaluations par **dimension** (§6).

3. Vocabulaire (glossaire + bascule Comply ↔ Regul)

Concept	Comply	Regul
Entité auditée	entité / entités	assujetti / assujettis
Prestataire	cabinet	régulateur
Auditeur	auditeur	contrôleur
Objet de travail	Missions	Contrôles
Mesure	recommandation	mesure
Portail	Portail Client	Portail Assujetti

- **Rôles de mission :** `Chef de mission` (`lead_auditor`), `Associé` (`associate`), `Auditeur`.
- **Rôles client :** `Approbateur`, `Contributeur`, `Lecteur`.
- **Constat** = *finding*. **Preuve** = *evidence*. **Cadrage** = phase de scoping.
- **IIC** = Infrastructure d'Information Critique (criticité élevée).

4. Valeurs autorisées (enums) — la « grammaire » des données

Utilise **exactement** ces valeurs (clé technique) ; les libellés FR sont pour l'affichage.

- **Statut de mission** (`mission_status`, 7, ordonnés) : `initialization` (Initialisation) → `scoping` (Cadrage) → `planning` (Planification) → `fieldwork` (Travaux) → `internal_review` (Revue interne) → `client_review` (Validation client) → `closure` (Clôture).
- **Statut d'évaluation** (`AssessmentStatus`) : `draft` (Brouillon), `submitted` (Soumis), `in_review` (En revue), `approved` (Approuvé), `rejected` (Rejeté).
- **Niveau de conformité** : `nc` (Non conforme), `pc` (Partiellement conforme), `lc` (Largement conforme), `c` (Conforme), `na` (Non applicable).
- **Classification de constat** (`FindingClassification`) : `major_nc` (non-conformité majeure), `minor_nc` (mineure), `observation`, `strength` (point fort).

- **Priorité** (constat & action) : `critical`, `high`, `medium`, `low`.
- **Étape de validation** (`ValidationStage`) : `auditor_submitted` → `lead_review` → `associate_review` → `client_review`. **Décision** : `approved` / `rejected`.
- **Statut CAR** : `open`, `client_responded`, `verified`, `closed`. **Vérification CAR** : `pending`, `accepted`, `rejected`.
- **Conclusion d'audit** : `conformant`, `partially_conformant`, `non_conformant`.
- **Niveau de risque** (`risk_level`) : `critical`, `high`, `medium`, `low`.
- **Rôle de mission** (`MissionRole`) : `lead_auditor`, `associate`, `auditor`.
- **Type de mission** (`MissionKind`) : `audit`, `continuous_supervision`. **Moteur** (`workflow_version`) : `audit`, `controle`.
- **Dimensions de score** (`score_dimension`) : `security`, `data_protection`, `resilience`, `integrity`, `governance`, `verifiability`, `human_factor`, `third_party`.

Échelles de risque : vraisemblance 1-4 (`Rare` / `Possible` / `Probable` / `Quasi-sûr`) × impact 1-4 (`Mineur` / `Modéré` / `Majeur` / `Critique`) ; $\text{exposition} = (\text{vraisemblance} \times \text{impact} / 16) \times 100$.

Traitements : `untreated`, `reduce`, `accept`, `transfer`, `avoid`. **Heures estimées** par contrôle : ordre de grandeur 2 à 8 h.

Regul / incidents (si édition régulateur) : gravité incident `faible/moyen/eleve/critique` ; statut `declared/triage/notified/resolved/closed` ; catégorie

`intrusion/ransomware/fuite_donnees/deni_service/autre`. Mesures graduées (ordre) : `recommandation` → `mise_en_demeure` → `injonction` → `sanction`.

5. Jeux d'options centralisés (pour des profils clients réalistes)

- **Effectifs** : Moins de 50 · 50 à 250 · 250 à 1 000 · 1 000 à 5 000 · Plus de 5 000.
- **Chiffre d'affaires (FCFA)** : Moins de 100M · 100M-500M · 500M-1Md · 1Md-5Mds · 5Mds-20Mds · Plus de 20Mds FCFA.
- **Secteurs** (23) : Administration publique, Agriculture, Assurance, Banque / Finance, BTP / Construction, Commerce / Distribution, Conseil, Défense, Éducation / Formation, Énergie, Hôtellerie / Restauration, Immobilier, Industrie / Manufacturing, Logistique / Transport, Médias / Communication, Mines / Extraction, ONG / Associations, Santé / Pharmaceutique, Services aux entreprises, Télécommunications, Technologies / IT, Tourisme, Autre.
- **Pays** (18) : Bénin, Burkina Faso, Cameroun, Canada, Côte d'Ivoire, France, Gabon, Guinée, Mali, Maroc, Maurice, Niger, RD Congo, **Sénégal**, Suisse, Togo, Tunisie, Autre. → **Par défaut, privilégier Sénégal** puis la zone UEMOA.
- **Type d'org** : Cabinet de conseil · Client · Groupe / Holding.
- **Types d'entité (Regul)** : ministère, direction générale, agence, société nationale, opérateur, institution financière, autre.
- **Criticité** : `eleve` (IIC) · `standard`.

6. Référentiels disponibles

Deux catalogues **distincts**.

6.1 Référentiels d'audit (table frameworks)

Nom	slug	Version / éditeur	Catégorie	Taille
ISO/IEC 27001	iso-27001	2022 (Annexe A)	conformité	—
NIST Cybersecurity Framework	nist-csf	2.0	conformité	—
COBIT	cobit-2019	2019	gouvernance	—
ITIL	itil-v4	4	gouvernance	—
Audit SI	audit-si	—	conformité	6 domaines, 79 contrôles
Due Diligence Technique	due-diligence-tech	—	évaluation	5 domaines, 42 contrôles
Maturité Digitale	maturite-digitale	—	évaluation	6 domaines, 46 contrôles
PSSI-ES — Sénégal	pssi-es	2017	conformité	11 domaines, ~213-224 contrôles

6.2 PSSI-ES (le référentiel « signature » Sénégal)

« Politique de Sécurité des Systèmes d'Information de l'État du Sénégal », **Instruction présidentielle N° 003/PR du 03 janvier 2017** — Commission Nationale de Cryptologie / Présidence de la République du Sénégal. Structure officielle : **11 chapitres, 30 objectifs, 155 règles** (contenu seedé : 11 domaines, ~213-224 contrôles).

11 domaines (codes) : **ORG** (Organisation de la sécurité), **PER** (Sécurité du personnel), **ACQ** (Acquisition & développement), **ACT** (Gestion des actifs), **FRN** (Relation fournisseurs), **PHY** (Sécurité physique), **LOG** (Sécurité logique), **EXP** (Exploitation), **CLM** (Cloud / mobiles / télétravail), **INC** (Gestion des incidents), **AUD** (Audit & conformité). Contrôles codés **REG <objectif>--<n>** (ex. **REG 6-1**), avec mapping ISO 27001 et spécificités sénégalaises (**AQSSI, ASSI, HFD, ADIE, STCC-SSI, ARTP, Commission nationale de cryptologie**, obligation d'hébergement national des données).

6.3 Catalogue réglementaire (table regulatory_catalog, ~22 obligations légales)

≠ **contrôles d'audit** : ce sont des obligations juridiques. Sénégal : **CDP-SN** (Loi n°2008-12, données personnelles, autorité **CDP**), **CYBER-SN** (Loi n°2008-11, cybercriminalité), **SINFO-SN** (Loi n°2008-10, transactions électroniques), **BANK-SN** (Loi n°2008-26), **DEC721-SN** (Décret 2008-721). Plus UEMOA / CIMA / CEDEAO ; international : **RGPD** (UE 2016/679), **PCI-DSS**, **ISO 27001**.

7. Workflows & moteurs de mission

Le moteur est choisi **par org** par le super-admin et **figé par mission** à la création (`workflow_version`).

7.1 Moteur Audit (audit complet)

Phases : **Cadrage** → **Planification** → **Travaux** → **Revue interne** → **Validation client** → **Clôture** → **(Plan d'action)**. Le client est **approbateur** : il approuve/rejette **par contrôle** (étape bloquante `client_review`).

7.2 Moteur Contrôle (ex. DCSSI)

Phases (5) : **Cadrage** → **Planification** → **Travaux** → **Revue** → **Clôture** — **pas** de validation client.

L'assujetti est **contributeur** : il laisse des **observations non bloquantes**. Le sous-onglet « Risques » du cadrage est désactivé.

7.3 Supervision continue (Regul)

Supprime la validation client ; « Clôture » devient « Clôture revue » (clôt un **cycle trimestriel**, pas la mission).

Statuts de cycle : `planned`, `in_progress`, `closed`.

7.4 Détails transverses

- **Sous-onglets de cadrage** : Périmètre, Risques, Acteurs, Documents, Questionnaire (le moteur Contrôle retire Risques ; Questionnaire optionnel).
- **Assistant de création (6 étapes)** : Référentiel → Cible (Client / Filiale) → Périmètre → Équipe → Calendrier → Confirmation (une étape « Engagement » précède pour les groupes).
- **Travaux guidés (4 étapes)** : Observer → Documenter → Analyser → Validation.
- **Kanban de revue** (colonnes) : Soumis · Revue Lead · Revue Associé · Revue Client · Validé.
- **Liaison question ↔ contrôle** : les questions de cadrage alimentent l'évaluation des contrôles (mapping question→contrôle).

8. Modèle de score de confiance

Score = **6 axes** (radar) + **3 facteurs** transverses (coefficients ≤ 1 qui ne peuvent que **tempérer**, jamais gonfler).

- **6 axes** : `security` (Sécurité), `data_protection` (Protection des données), `resilience` (Résilience & continuité), `integrity` (Intégrité & fiabilité), `governance` (Gouvernance & éthique), `verifiability` (Transparence & vérifiabilité).
- **3 facteurs** : `human_factor` (Facteur humain, 0.15), `third_party` (Écosystème / tiers, 0.15), `assurance` (Assurance des preuves, 0.2 — dérivé de la fraîcheur/documentation des preuves).
- Plancher de coefficient 0.5 ; fenêtre de fraîcheur des preuves **12 mois** ; poids de scellement par étape (lead_review 0.5, associate_review 0.8, client_review 1).
- Chaque **contrôle** porte une **dimension primaire** → le score agrège les évaluations par dimension. Un score « qui prend vie » suppose donc des évaluations **réparties sur plusieurs dimensions** et des **preuves récentes**.

9. Guide de réalisme (règles d'or)

Cohérence avant volume. Une démo crédible raconte une histoire cohérente, pas un tas de lignes.

1. **Localisation** : noms d'organisations et de personnes **sénégalais / ouest-africains** (ex. « Téranga Finances », « Sonatel Services », « Banque de Dakar » ; personnes : « Awa Diallo », « Mamadou Sow », « Fatou Ndiaye »). Emails cohérents avec le domaine (`prenom.nom@<slug-entreprise>.sn`). Montants en **FCFA**. Tout en **français**.
2. **Secteur** ↔ **référentiel** : une banque/assurance → ISO 27001, PCI-DSS ; un ministère / société nationale → **PSSI-ES** + moteur **Contrôle** ; une entreprise IT → Audit SI / Maturité Digitale.
3. **Stade** ↔ **contenu** (règle la plus importante) : - `scoping` : périmètre + acteurs, **0 évaluation, 0 constat**. - `fieldwork` : couverture partielle (~40-70 %), mélange de statuts (`draft` , `submitted` , `in_review` , quelques `approved`), **quelques constats**, CAR `open` / `client_responded` , observations client `pending` . - `closure` : couverture ~100 % , **tous approuvés**, cascade de validation complète (jusqu'à `client_review` en Audit), constats résolus (CAR `verified` / `closed`), **un rapport** généré, une conclusion d'audit.
4. **Distribution des constats** : majorité `minor_nc` / `observation` , quelques `major_nc` , de rares `strength` . La **priorité** doit suivre la gravité (`major_nc` → `high` / `critical`). Un constat = un énoncé **concret et vérifiable** (ex. « Aucune journalisation centralisée des accès aux systèmes sensibles »), pas un libellé générique.
5. **Cohérence des dates** : cadrage < travaux < revue < clôture ; entretiens datés dans la fenêtre de la mission ; CAR avec échéance future (~+30 j) en cours, passée si `closed` .
6. **Score cohérent** : le score et le radar **découlent** des évaluations — ne pas poser un score « à la main » incohérent avec des contrôles majoritairement non conformes. Répartir les contrôles évalués sur **plusieurs dimensions** pour un radar lisible.
7. **Risques liés aux constats** : un scénario de risque crédible **pointe un contrôle réellement évalué** (ex. « Intrusion non détectée » ↔ contrôle de journalisation faible), coté sur la grille 4x4, avec un traitement (`reduce` / `open` ...).
8. **Rôles réalistes** : un chef de mission + un associé + éventuellement un auditeur ; côté client un contact **RSSI** (« Responsable de la Sécurité des SI »).

10. Scénario de référence (ce qu'une bonne démo contient déjà)

Le générateur intégré (`seed-demo-data`) produit une démo de référence — à **imiter et enrichir** :

- **Org client de démo** : « **Téranga Finances** » (secteur finance, `.sn`).
- **Contact / interviewé** : « **Awa Diallo** », **RSSI**, dépt « Sécurité des SI », `awa.diallo@teranga-finances.sn` .
- **3 missions à des stades variés** : 1. **Audit — Clôture** : couverture 100 % , tout approuvé ; constats = 1 `strength` (« revue des accès à privilèges formalisée et tracée trimestriellement ») + 1 `minor_nc` /medium (« politique de contrôle d'accès non revue depuis > 12 mois ») ; CAR `verified` / `closed` ; **rapport PDF** généré ; entretien « completed ». 2. **Contrôle — Travaux** : couverture ~60 % ; constats = 1 `major_nc` /high (« Aucune journalisation centralisée des accès aux systèmes

sensibles ») + 1 `minor_nc` /low (« sauvegardes sans tests de restauration documentés ») ; CAR `open / client_responded` ; 1 observation client `pending` . 3. **Audit — Cadrage** : état initial vide (0 évaluation, 0 constat).

- **Planification** : `risk_level` réparti (high/medium/low/critical), `estimated_hours` 2-8 h.
- **Registre de risques (2 scénarios)** liés à des contrôles réels : (1) « Intrusion non détectée sur les systèmes sensibles » (vuln « Journalisation partielle des accès », L3×I4, détectif) ; (2) « Indisponibilité prolongée après incident » (vuln « Restaurations non testées », L2×I3, correctif).
- Sélection du référentiel : la mission en clôture prend le **plus petit** référentiel (moins de contrôles) pour atteindre 100 % de couverture de façon crédible.

11. Anti-patterns (à éviter absolument)

- Noms/villes/monnaie hors contexte (US/EU par défaut, « \$ », « Acme Corp »).
- Une mission en `scoping` qui contient déjà des constats ou un rapport.
- Une mission en `closure` avec des évaluations `draft` ou une cascade de validation incomplète.
- Priorité de constat incohérente avec sa classification.
- Score/radar posés arbitrairement, sans évaluations sous-jacentes.
- Valeurs d'enum inventées (elles seront rejetées par les `CHECK`).
- Un seul type de constat partout (tout `major_nc` , ou tout `strength`).
- Un scénario de risque qui ne pointe aucun contrôle évalué.

Source : code Gëstu Comply (schéma, migrations, `src/lib/constants.ts` , `mission-constants.ts` , `seed-demo-data` , RFC 0002/0003/0006, CONTEXT.md, BRAND.md). En cas de doute, la base fait foi (contraintes `CHECK` et types de `database.types.ts`).